

Proyecto 3 Avances

Tacos El Pepe

Pablo José Vásquez Santos

24757

1. Alcance de la entrega

La entrega incluye la implementación y documentación de los siguientes elementos:

- Roles reales en PostgreSQL con permisos granulares.
- Permisos definidos mediante GRANT y REVOKE.
- Usuario técnico proy3 para la conexión del backend.
- Autenticación con sesión.
- Protección de endpoints según rol.
- Protección de rutas y vistas en el frontend.
- Datos para cada rol

2. Cambios implementados

2.1 Seguridad real en PostgreSQL

Se agregó el script db/init/sql/seguridad_rols.sql, encargado de crear exactamente los cinco roles de negocio exigidos por la rúbrica:

- rol_admin
- rol_cajero
- rol_cocinero
- rol_inventario
- rol_analista

Además, se creó el usuario técnico proy3 como usuario de conexión para el backend. Este usuario no representa un rol de negocio; su función es iniciar sesión en PostgreSQL y activar el rol adecuado por request mediante SET LOCAL ROLE.

También se aplicaron medidas de seguridad como revocación de privilegios por defecto, asignación explícita de permisos por rol, permisos sobre secuencias para roles que insertan datos, permisos sobre tipos enum y revocación del permiso CREATE sobre el esquema public para PUBLIC.

2.2 Expansión del modelo de roles

El tipo enumerado tipo_rol_empleado fue ampliado para soportar cinco valores: admin, cajero, cocinero, inventario y analista. Esto permite que el rol del empleado quede formalizado tanto en el modelo de datos como en la lógica de autenticación y autorización.

2.3 Usuario técnico y credenciales de calificación

Se alineó la configuración del proyecto con el requerimiento del enunciado para usar las credenciales proy3 / secret. El backend ahora se conecta a PostgreSQL con DB_USER=proy3 y DB_PASSWORD=secret.

La inicialización del contenedor de base de datos se mantiene con un usuario bootstrap separado, postgres, para poder crear objetos, usuario técnico y permisos de forma limpia y reproducible.

2.4 Autenticación con sesión y usuarios semilla

Se reemplazaron los hashes placeholder por hashes bcrypt válidos directamente en db/init/sql/datos_prueba.sql. Con esto, las cuentas de prueba quedan funcionales desde la inicialización de la base de datos, sin depender de un script auxiliar.

Email	Rol	Contraseña
jose.perez@tacospepe.gt	admin	admin123
carlos.hernandez@tacospepe.gt	cajero	admin123

roberto.villalobos@tacospepe.gt	cocinero	admin123
noemi.soto@tacospepe.gt	inventario	admin123
esteban.castro@tacospepe.gt	analista	admin123

2.5 Autorización del backend

Se incorporó una capa de autorización por rol en el backend. Ahora no basta con estar autenticado: cada endpoint protegido valida que el rol del usuario en sesión esté autorizado para ejecutar la operación.

- Middleware de autorización: valida si el rol del usuario en sesión puede acceder al endpoint.
- Transacción con rol activo: cada request protegido activa el rol de PostgreSQL correspondiente con SET LOCAL ROLE.

Con esto, la seguridad existe en dos niveles: aplicación y DBMS. Si un rol intenta ejecutar una acción no permitida, la aplicación responde con error y PostgreSQL también puede rechazar la operación por permisos insuficientes.

2.6 Protección de rutas y vistas en frontend

El frontend fue actualizado para soportar los cinco roles y restringir la navegación visible y el acceso por URL directa según el rol autenticado.

Rol	Home	Vistas permitidas
admin	/dashboard	Todo el backoffice
cajero	/pos	/dashboard, /pos, /pedidos, /reportes, /analitica
cocinero	/pedidos	/pedidos
inventario	/insumos/reabastecer	/insumos, /insumos/nuevo, /insumos/:id/editar, /insumos/reabastecer
analista	/dashboard	/dashboard, /reportes, /analitica

También se ajustaron los botones de acciones sobre pedidos para que el frontend no muestre transiciones que el rol actual no puede ejecutar.

2.7 Flujo de estados de pedidos según rol

Se definió y aplicó una matriz de transiciones por rol para el cambio de estado de pedidos:

Rol	Transiciones permitidas
admin	Cualquier transición válida del flujo
cajero	pendiente → aprobado, pendiente → cancelado, aprobado → cancelado, finalizado → entregado
cocinero	aprobado → en_proceso, en_proceso → finalizado

El backend devuelve 403 cuando el rol no puede ejecutar la transición solicitada y 409 cuando el cambio de estado no es válido para el estado actual del pedido.

3. Resumen de roles

Rol app	Rol DB	Objetivo principal	Permisos de alto nivel
admin	rol_admin	Administración completa	CRUD total sobre catálogo, inventario, compras, pedidos, reportes y vistas
cajero	rol_cajero	Operación de caja y POS	Crear pedidos, operar pagos, consultar reportes y analítica
cocinero	rol_cocinero	Operación de cocina	Consultar pedidos y avanzar estados de cocina
inventario	rol_inventario	Abastecimiento y stock	CRUD de insumos, registrar compras y consultar stock crítico
analista	rol_analista	Lectura ejecutiva	Solo lectura sobre dashboard, reportes y analítica

4. Enlace del repositorio

Rama de entrega: <https://github.com/PabloVS044/TacosElPepe/tree/proyecto-3>